

SIMATS ENGINEERING

ASSESSMENT TOOL 3

Name	Abinesh M
Register Number	192465050
Date	
Time	1 Hr

COURSE NAME: **Cybersecurity Incident Handling And Response**

COURSE CODE: **CSA6001**

COURSE OUTCOME COVERED

C04: Appraise containment, eradication, recovery strategies by selecting appropriate techniques such as isolation, malware removal, patch management, system restoration to ensure secure operations. (BL3, BL4)

Activity Tool : System Recovery and Backup Validation (Low)

Assessment Tool Weightage: 10%

Code of Conduct:

*I Abinesh M 192465050 (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.
I understand that any violation of academic integrity rules will result in disciplinary action.*

Signature of the student:

RUBRICS FOR CALCULATION:

Criteria	Weightage	Level 4 (Exemplary)	Level 3 (Proficient)	Level 2 (Developing)	Level 1 (Beginning)
Backup Identification and Validation	25%	Accurately identifies appropriate backups and thoroughly validates their integrity, completeness, availability, and freedom from malware before restoration.	Identifies and validates suitable backups with minor omissions.	Performs basic backup validation but misses important integrity or security checks.	Unable to identify or validate an appropriate backup.
System Restoration and Recovery	25%	Successfully restores systems and data using trusted backups while maintaining data integrity and following a secure recovery process.	Restores systems and data correctly with minor errors or omissions.	Performs basic restoration but encounters issues with data integrity or recovery procedures.	Unable to successfully restore the affected systems or data.
Recovery Security and Hardening	20%	Effectively applies patches, secure configurations, access controls, network segmentation, and other security measures before returning systems to operation.	Applies appropriate security controls with minor gaps.	Implements basic security measures but leaves some weaknesses unresolved.	Fails to apply appropriate security controls during recovery.
Post-Recovery Validation and Monitoring	15%	Thoroughly validates system integrity, malware removal, vulnerabilities, configurations, and connectivity and establishes continuous monitoring after recovery.	Performs appropriate validation and monitoring with minor omissions.	Performs basic validation but misses important security or monitoring checks.	Unable to properly validate or monitor the recovered systems.
Documentation and Recovery Report	15%	Provides clear, professional documentation covering backup validation, restoration steps, security checks, recovery results, evidence, and recommendations.	Documentation is well organized and includes most required recovery details.	Documentation is partially organized with limited evidence or recovery details.	Documentation is incomplete, poorly organized, and lacks supporting evidence.

System Recovery Planning and Backup Validation

Question 1: System Recovery Planning

A ransomware attack affecting several critical servers puts the organization in a race between restoring operations quickly and avoiding reintroducing the same threat during recovery. As a cybersecurity consultant, my role is to build a structured recovery plan that sequences restoration by business impact, confirms each system is safe before it returns to production, and balances speed against the risk of a repeat infection.

1. Pre-Recovery Groundwork

- **Confirm eradication first:** Recovery should not begin until the incident response team confirms the ransomware's entry point is closed and affected systems have been isolated, since restoring servers into a still-compromised network risks immediate re-encryption.
- **Establish a clean recovery environment:** Where possible, rebuild or restore into an isolated network segment first, verify cleanliness, and only then reconnect to the production network — rather than restoring directly onto the live network.
- **Inventory affected systems:** Build a complete list of every affected server, along with its role, dependencies, and available backup points, since recovery sequencing decisions depend on understanding how systems relate to one another.

2. Building the System Recovery Plan

- **Step 1 — Business Impact Analysis (BIA):** Work with business stakeholders to classify each affected system by criticality — revenue-generating systems, regulatory/compliance systems, and systems supporting other systems (domain controllers, DNS, authentication) typically rank highest.
- **Step 2 — Define Recovery Time Objectives (RTO) and Recovery Point Objectives (RPO):** For each critical system, establish how quickly it must be restored (RTO) and how much data loss is acceptable (RPO), which together determine which backup point to restore from and how much manual reconstruction may be needed.
- **Step 3 — Map dependencies:** Identify infrastructure systems that other applications depend on (Active Directory, DNS, network authentication, core databases) so they are restored before the applications that rely on them, avoiding a situation where a restored application server fails because its supporting services are still down.
- **Step 4 — Sequence the restoration:** Combine criticality, dependency order, and RTO/RPO targets into a single prioritized restoration sequence, documented so all responders work from the same plan during a high-pressure recovery window.
- **Step 5 — Assign roles and communication:** Define who executes each restoration step, who verifies it, and how status is communicated to business stakeholders throughout the process, since recovery typically involves multiple teams working in parallel.

3. Which Systems to Restore First

Priority Tier	Example Systems	Rationale
Tier 1 — Foundational	Domain controllers, DNS, core network infrastructure, backup servers	Everything else depends on these being available and trustworthy first
Tier 2 — Business-critical	Revenue systems, core production databases, customer-facing applications	Directly drives revenue and customer commitments; highest business impact if delayed
Tier 3 — Important support	Internal applications, reporting systems, secondary databases	Needed for normal operations but tolerates a short additional delay
Tier 4 — Lower priority	Archival systems, non-critical test/dev environments	Minimal immediate business impact; restored once higher tiers are stable

4. Security Considerations During Restoration

- Restore only from backups that have been validated as clean and free of the ransomware payload (see Question 2's validation process), never assuming a recent backup is automatically safe.
- Reset all credentials and rotate secrets/certificates before or during restoration, since the attacker may have harvested credentials prior to detonating the ransomware.
- Apply any security patches or configuration changes identified as the root cause before reconnecting restored systems to the network, so the same vulnerability cannot be immediately re-exploited.
- Restore into a segmented or monitored environment initially, watching for any sign of reinfection before fully reintegrating the system into production.
- Maintain a forensic copy of affected systems before wiping/restoring them, preserving evidence for the post-incident investigation and any legal or insurance requirements.

5. Balancing Speed and Safety

The recovery plan must reconcile pressure to restore operations quickly with the risk that rushed restoration reintroduces the ransomware or restores onto a still-vulnerable environment. In practice, this means Tier 1 and Tier 2 systems receive the most rigorous validation (since they are restored first and everything else depends on their integrity), while the overall timeline is communicated transparently to business stakeholders so that recovery speed does not come at the cost of skipping essential security verification steps.

6. Tools and Techniques Supporting Recovery

- **Immutable/air-gapped backup platforms (Veeam, Rubrik, Commvault with immutability):** provide backup copies that ransomware cannot encrypt or delete even with elevated access, making them the most trustworthy source for restoration.
- **Bare-metal and image-based recovery tools:** allow full server rebuilds from a known-good image rather than attempting to clean a live compromised system, which is often faster and more reliable for severely affected servers.
- **Isolated recovery environments (IRE) / clean rooms:** a network-segmented environment purpose-built for restoring and validating systems before they touch production, increasingly offered as a standard feature in enterprise backup platforms.
- **Configuration management tools (Ansible, Terraform, SCCM):** rebuild server configurations consistently and quickly, reducing manual reconstruction time for Tier 1 infrastructure and ensuring hardened settings are reapplied automatically.
- **IR/recovery orchestration platforms (SOAR):** coordinate and track the multi-team restoration workflow, ensuring each system's validation and sign-off steps are completed and documented before it is marked ready for production.

7. Example Recovery Timeline

A representative timeline illustrates how the recovery tiers and validation steps typically unfold across a multi-day ransomware recovery effort:

Phase	Typical Actions
Day 0–1	Containment confirmed; forensic images captured; recovery plan and priority tiers finalized with business stakeholders
Day 1–2	Tier 1 foundational systems (domain controllers, DNS, backup infrastructure) restored and validated in an isolated environment
Day 2–4	Tier 2 business-critical systems restored, credentials rotated, patches applied, then reconnected under close monitoring
Day 4–7	Tier 3 and Tier 4 systems restored as capacity allows; full environment placed under heightened monitoring
Day 7+	Post-incident review; backup strategy and detection gaps identified during recovery are remediated

Timelines vary significantly by organization size and the scope of the attack, but the underlying sequence — foundational systems first, followed by business-critical, then supporting systems — remains consistent across most ransomware recovery efforts.

Question 2: Backup Validation and Recovery

Restoring a critical database from a backup after a malware incident carries a real risk: if the backup itself is infected, incomplete, or corrupted, restoration can either reintroduce the malware or leave the business running on unreliable data. Before any restoration begins, I would run each candidate backup through a structured validation process covering integrity, timing, malware status, accessibility, and data consistency.

1. Backup Integrity Verification

- **Checksum/hash verification:** Compare the backup file's checksum against the value recorded at backup-creation time to confirm the file has not been corrupted or tampered with in storage.
- **Backup job logs:** Review the backup software's job logs to confirm the backup completed successfully without errors, warnings, or partial-failure flags that could indicate an incomplete capture.
- **Structural validation:** For database backups specifically, run the database engine's native consistency-check utility (e.g., DBCC CHECKDB for SQL Server, mysqlcheck for MySQL) against a restored copy to confirm the backup is structurally sound.

2. Date and Completeness Checks

- Identify the exact timestamp of each available backup and compare it against the known or estimated infection timeline to determine which backups predate the compromise.
- Confirm whether each backup is a full backup or an incremental/differential that depends on a prior full backup, ensuring the complete chain needed for restoration is available and intact.
- Cross-check backup scope against the production database schema to confirm no tables, indexes, or stored procedures are missing from the captured backup.

3. Malware Infection Screening

- **Scan in an isolated environment:** Restore the backup into a sandboxed, network-isolated environment — never directly onto production — and run updated antivirus/EDR scans against the restored files before considering the backup a candidate for production restoration.
- **Check backup age against dwell time:** If forensic analysis indicates the malware had a longer dwell time than initially assumed, even older backups may already contain the infection; extend the malware screening to backups predating the currently known compromise window.
- **Look for indicators, not just signatures:** In addition to signature-based antivirus scanning, check the restored copy for the same IOCs (file hashes, suspicious scripts, unusual stored procedures/triggers) identified during the malware investigation, since attacker-modified database objects can persist through a naive backup/restore cycle.

4. Accessibility and Data Consistency Checks

- **Accessibility testing:** Confirm the backup can actually be mounted/restored successfully in the isolated test environment — a backup that exists but cannot be

restored is not a viable recovery option and should be identified before, not during, the live recovery window.

- **Data consistency validation:** Compare row counts, key business records, and referential integrity constraints between the restored test copy and known-good application expectations to confirm the data is logically consistent and usable, not just technically restorable.
- **Application-level testing:** Where possible, point a test instance of the application at the restored database copy and run core business transactions to confirm the data supports normal application function, not just passes low-level database checks.

5. Making the Restoration Decision

Validation Outcome	Recommended Action
Clean, complete, and consistent	Proceed with restoration into production, followed by post-restore monitoring
Clean but incomplete/older than desired RPO	Restore as a baseline, then manually reconcile any transactions lost since that backup using application logs where available
Infected or containing attacker artifacts	Reject; move to the next older backup and repeat the full validation process
Fails accessibility/restoration test	Reject as non-viable; flag backup infrastructure for review to prevent recurrence

Only a backup that passes all five checks — integrity, date/completeness, malware screening, accessibility, and data consistency — should be restored to production. Every validation step and its outcome is documented, both to support the final restoration decision and to identify any gaps in the backup strategy itself (e.g., insufficient backup frequency or inadequate isolation of backup storage) that should be addressed to reduce risk in future incidents.

6. Tools Supporting Backup Validation

- **Hash verification utilities (built-in backup software checksums, sha256sum):** confirm bit-for-bit integrity of the backup file against its recorded value at creation time.
- **Isolated sandbox/lab environment:** a network-segmented restoration target used exclusively for validation, ensuring a potentially infected backup can never reach production or other systems during testing.
- **Updated antivirus/EDR with fresh signatures:** scanning restored files with current definitions is essential, since a backup taken before the malware's signature existed may pass an outdated scan but still be infected.

- **Database consistency utilities (DBCC CHECKDB, mysqlcheck, pg_verify):** confirm structural soundness and catch corruption that a simple file-level integrity check would miss.
- **YARA rules and IOC-matching scripts:** search restored files and database objects (stored procedures, triggers, scheduled jobs) for the specific indicators identified during the malware investigation, catching attacker artifacts that generic antivirus signatures might not flag.

7. Example Backup Validation Matrix

Where multiple backups are available, comparing them side by side against each validation criterion makes the restoration decision explicit and defensible:

Backup	Integrity	Malware Scan	Consistency	Decision
Yesterday	Pass	Fails — IOC match found	N/A	Reject
3 days ago	Pass	Clean	Pass	Use for restoration
1 week ago	Pass	Clean	Pass	Hold as fallback

In this example, the most recent backup is rejected because it already contains indicators tied to the malware, making the three-day-old backup the earliest clean option — with any transactions from the intervening days reconciled manually from application logs where possible, and the one-week-old backup retained as a fallback if further issues surface with the chosen restore point.

Conclusion

Both scenarios point to the same underlying principle: recovery is only as trustworthy as the process used to validate what is being restored. A recovery plan that sequences systems by business priority and dependency, but skips security verification, risks restoring the organization straight back into a compromised state. Likewise, a backup that looks recent and complete but has not been screened for malware or tested for consistency can quietly reintroduce the very incident it was meant to recover from. Effective recovery therefore combines careful prioritization with disciplined, evidence-based validation at every restoration step — ensuring the organization returns to a state that is not just operational, but genuinely secure.

Comparing the Two Scenarios

Aspect	Question 1: Recovery Planning	Question 2: Backup Validation
Primary focus	Sequencing and restoring many systems by business priority	Confirming a specific backup is safe and usable before restoring it

Aspect	Question 1: Recovery Planning	Question 2: Backup Validation
Key driver	Business Impact Analysis, RTO/RPO, dependency mapping	Integrity, malware screening, and data consistency checks
Main risk if skipped	Restoring systems out of order, or into a still-vulnerable network	Restoring an infected or incomplete backup into production
Success measure	Critical operations resumed within target RTO, securely	Restored data confirmed clean, complete, and consistent

Together, these two disciplines form a complete recovery capability: a prioritization framework determines what to restore and in what order, while rigorous backup validation ensures each individual restoration is trustworthy. Neither is sufficient alone — a well-sequenced plan built on compromised backups fails just as surely as a validated backup restored without regard for business priority or dependency order.